Relazione – Implementazione firewall pfSense DVWA S3_L5

1. Introduzione

L'attività ha previsto la progettazione e l'implementazione di una rete segmentata, utilizzando pfSense come firewall per il controllo del traffico tra due sottoreti:

- **LAN (192.168.10.0/24)** → client (Kali Linux)
- **OPT1 (192.168.20.0/24)** → server (Metasploitable 2 con DVWA)

L'obiettivo è stato analizzare il comportamento del firewall in diversi scenari, verificando:

1. la comunicazione tra host appartenenti a reti differenti;
2. l'effetto di una regola di blocco totale del traffico;
3. il filtraggio selettivo sulla porta 80 (HTTP), consentendo il traffico necessario (Ping) e bloccando l'accesso al servizio web DVWA senza interrompere la connettività di rete.

2. Architettura e topologia di rete

L'ambiente è stato realizzato in ambiente virtualizzato ed è composto da tre macchine principali:

- pfSense, utilizzato come firewall e router per il controllo e il filtraggio del traffico tra le reti;
- Kali Linux, configurato come macchina client;
- Metasploitable 2, configurato come macchina server e utilizzato per ospitare l'applicazione web DVWA.

Segmentazione della rete

La rete è stata suddivisa in due sottoreti con ruoli distinti:

- **LAN (192.168.10.0/24)** → client (Kali Linux), utilizzato per test di connettività e accesso ai servizi;
- **OPT1 (192.168.20.0/24)** → server (Metasploitable 2), che ospita l'applicazione web DVWA.

Questa suddivisione consente di separare sistemi con funzioni diverse, migliorando la sicurezza complessiva.

Ruolo del firewall pfSense

Il traffico tra le sottoreti è gestito esclusivamente dal firewall pfSense, che:

- controlla le comunicazioni tra client e server;
- applica le regole di sicurezza;
- consente o blocca il traffico in base alle policy configurate.
-

Esempio in ambito aziendale e vantaggi della segmentazione

L'architettura simula una rete aziendale in cui i client sono separati dai server, consentendo di:

- impedire agli utenti di accedere direttamente ai sistemi critici;
- limitare l'utilizzo dei servizi ai soli necessari;
- controllare le comunicazioni tra client e server.

Questa segmentazione consente inoltre di ridurre la superficie di attacco, isolare i sistemi critici e applicare politiche di sicurezza mirate.

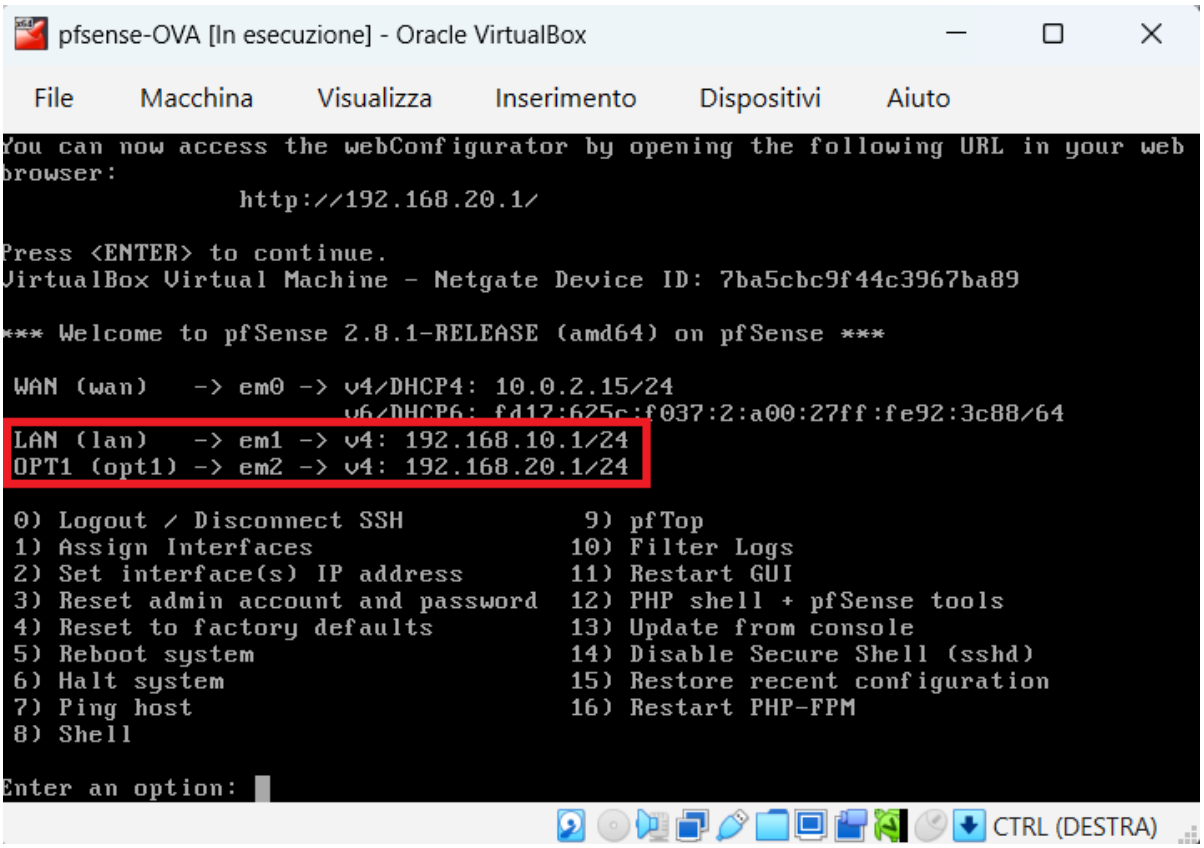


Figura 1 – Configurazione interfacce pfSense

3. Configurazione degli host

Gli host sono stati configurati con indirizzi IP coerenti con la segmentazione di rete:

- **Kali Linux** → rete LAN (192.168.10.0/24)
- **Metasploitable 2** → rete OPT1 (192.168.20.0/24)

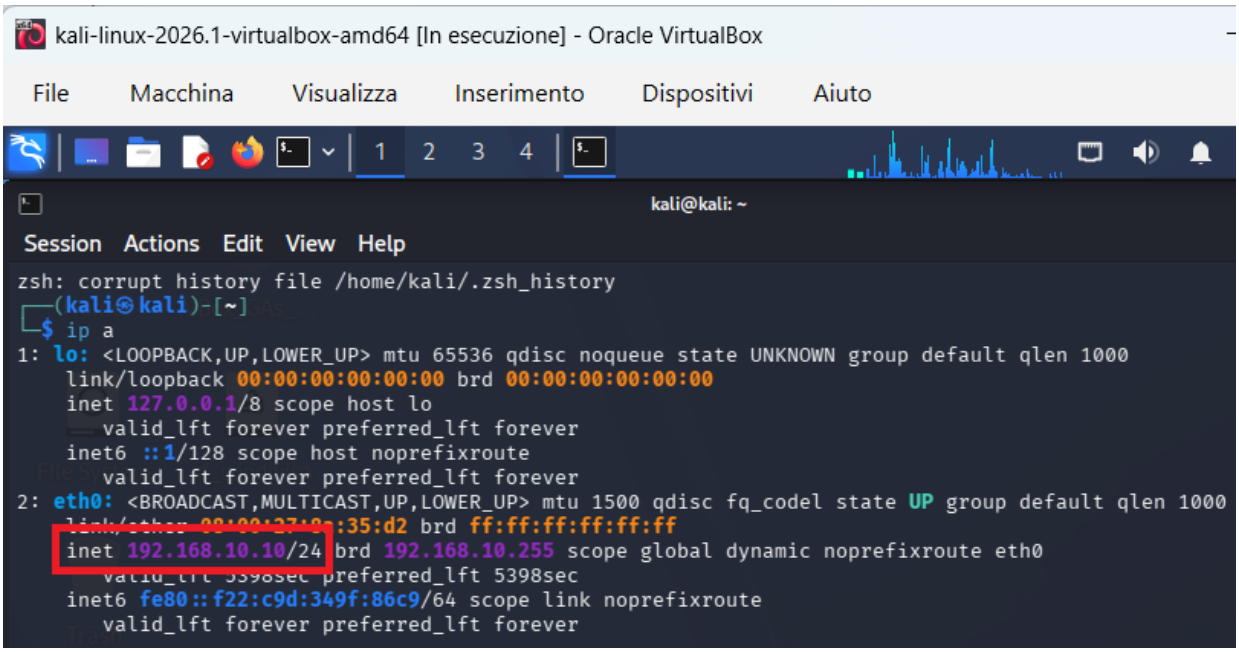


Figura 2 – Configurazione indirizzo IP della macchina Kali Linux (rete LAN)

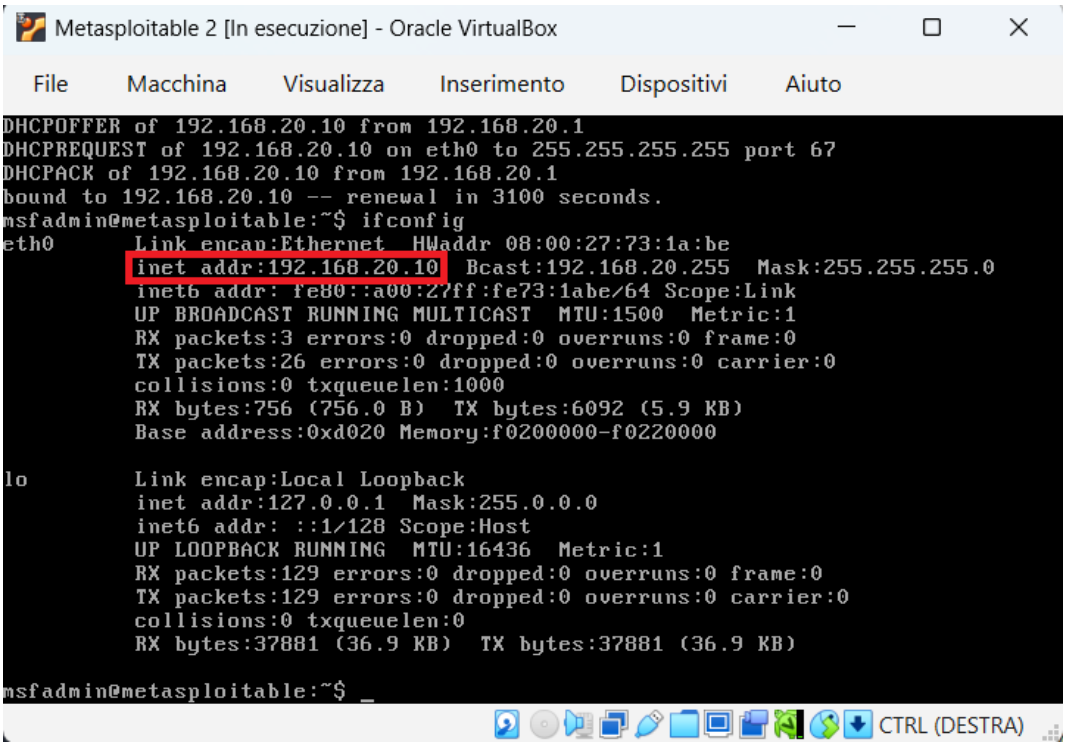


Figura 3 – Configurazione IP Metasploitable

Questa configurazione consente l'isolamento tra le sottoreti e il controllo del traffico tramite firewall pfSense.

4. Verifica della connettività iniziale

Sono stati eseguiti test per verificare il corretto funzionamento della rete:

- **Ping (ICMP)** da Kali Linux a Metasploitable 2 → esito positivo
- **Accesso DVWA (HTTP)** tramite browser → esito positivo

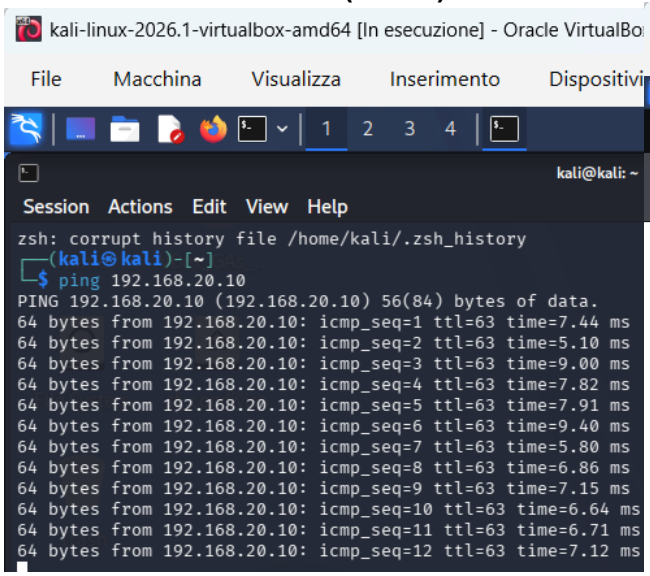


Figura 3 – Ping riuscito

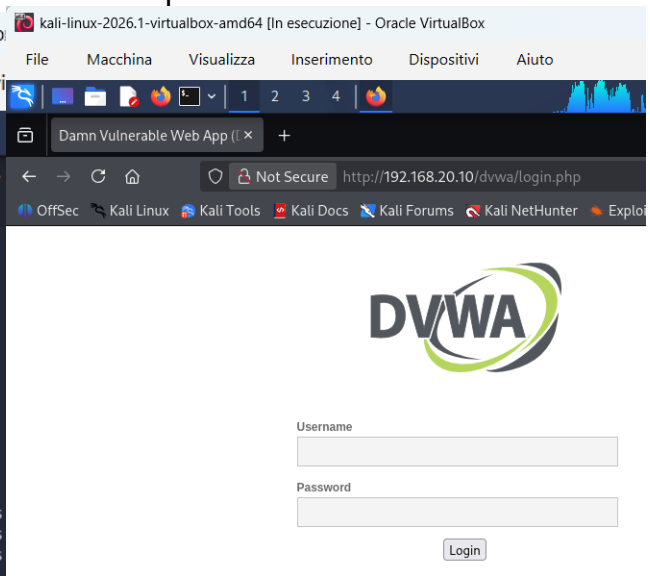


Figura 4 – Accesso DVWA riuscito

Analisi

In assenza di regole restrittive, il firewall consente il traffico tra le reti, permettendo sia la verifica della connettività (ICMP) sia l'accesso ai servizi web (HTTP).
Questo conferma il corretto instradamento del traffico e l'assenza di restrizioni attive.

5. Implementazione del blocco totale

È stata configurata una regola firewall con priorità superiore alla regola di default:

- **Action:** Block
- **Protocol:** Any
- **Source:** LAN
- **Destination:** Any

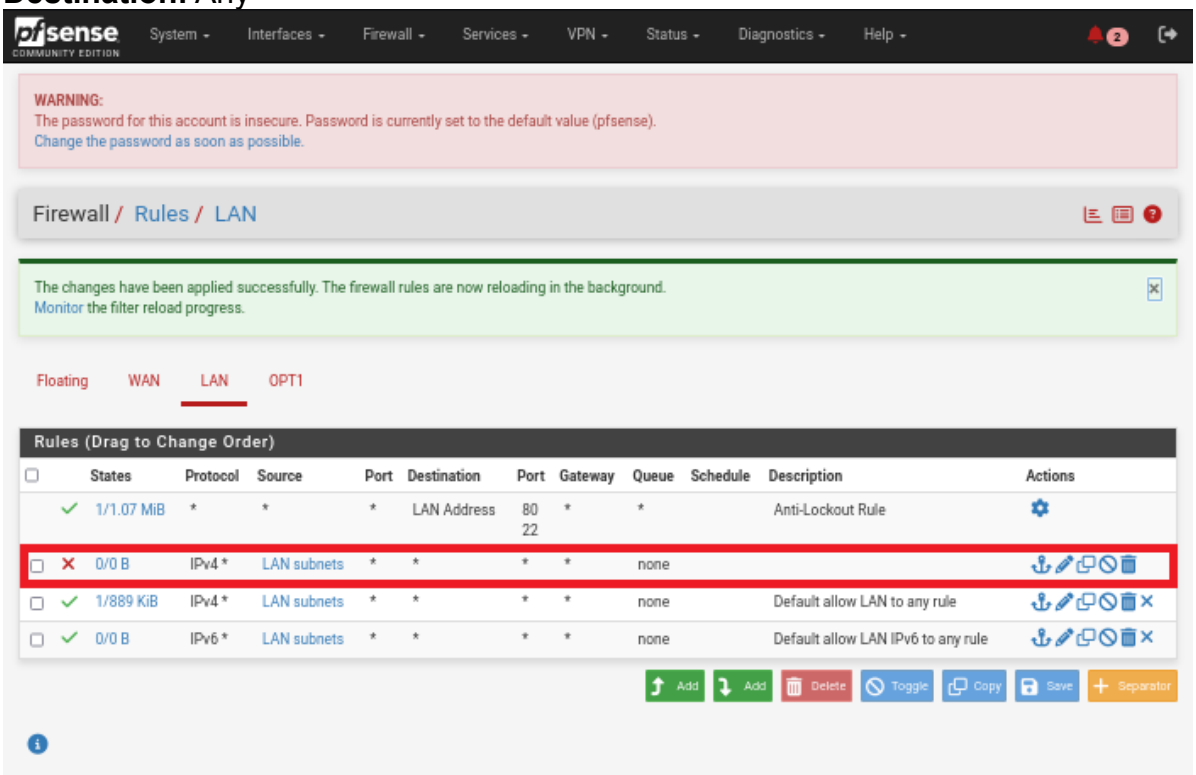


Figura 5 – Configurazione regola blocco totale

Verifica

- **Ping (ICMP)** → fallito
- **Accesso DVWA (HTTP)** → non disponibile (timeout)

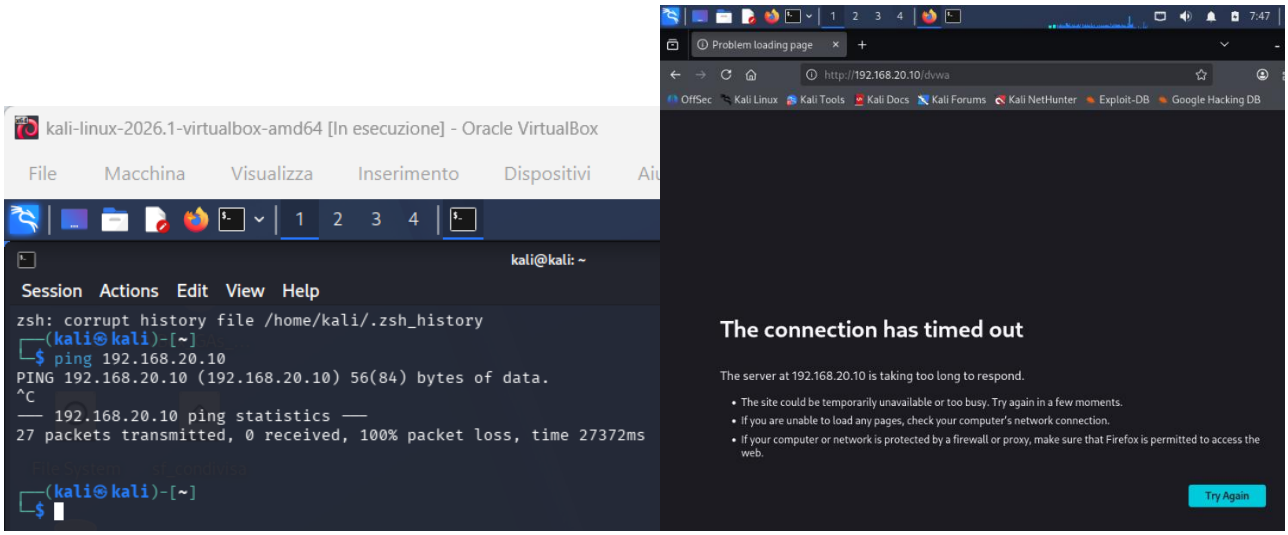


Figura 6 – Blocco totale del traffico tra le sottoreti

Analisi tecnica

Il firewall interrompe completamente la comunicazione tra le reti.
Questo conferma che la regola di blocco viene applicata correttamente a tutto il traffico proveniente dalla rete LAN, impedendo qualsiasi tipo di comunicazione tra client e server.

6. Transizione tra le regole firewall

Dopo i test sul blocco totale, la regola è stata disabilitata e sostituita con una regola di filtraggio selettivo per bloccare il traffico HTTP (porta 80) verso il server Metasploitable 2. Sono quindi stati eseguiti nuovi test per verificare il comportamento del firewall nella nuova configurazione.

7. Implementazione del blocco selettivo (HTTP)

È stata configurata una regola per bloccare il traffico HTTP (porta 80) verso il server Metasploitable 2.

Parametri della regola

- **Protocol:** TCP
- **Source:** LAN
- **Destination:** 192.168.20.10
- **Port:** 80 (HTTP)
- **Action:** Block

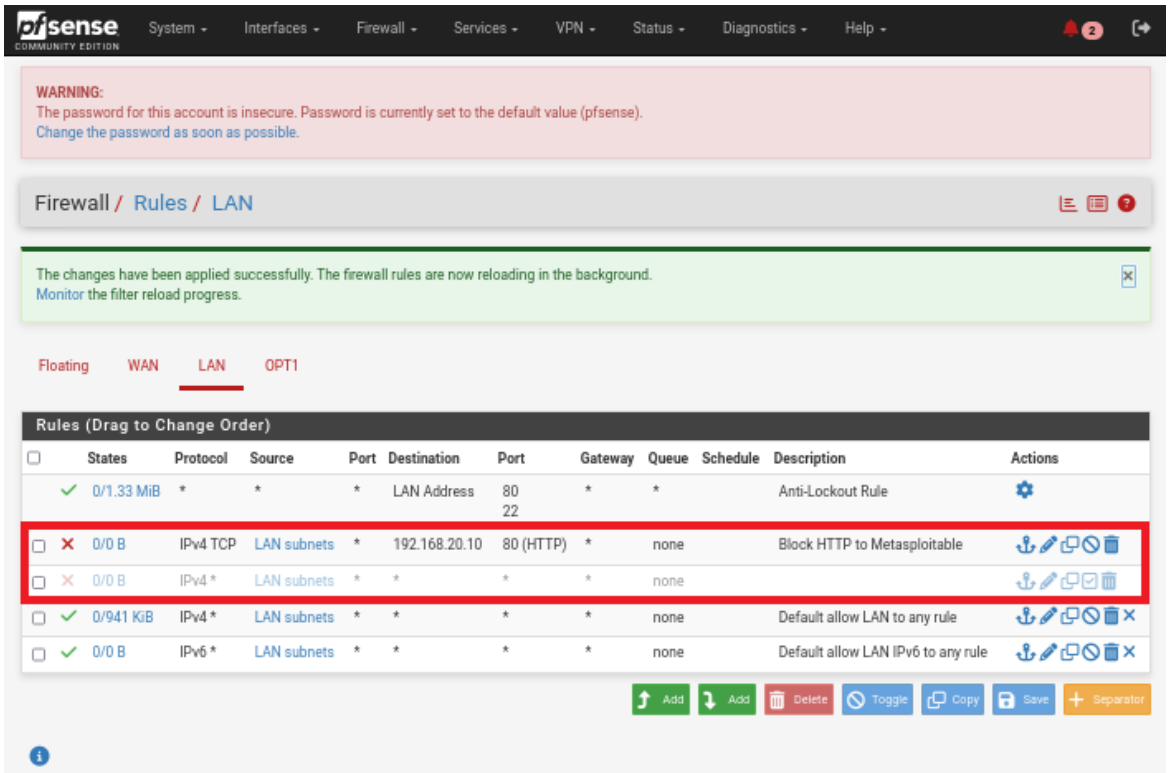
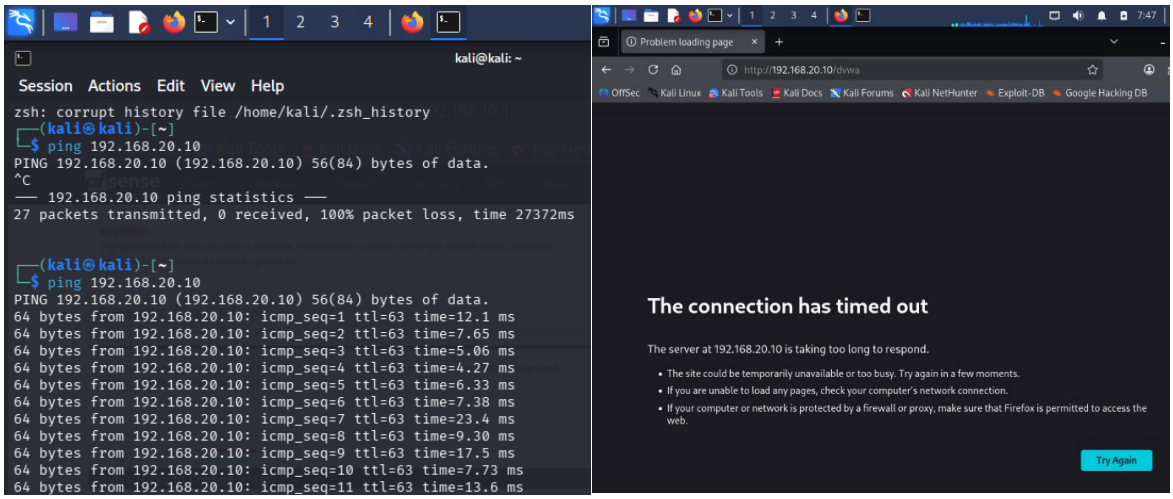


Figura 7 – Configurazione regola blocco HTTP

8. Verifica del comportamento selettivo

Sono stati eseguiti test per verificare il funzionamento della regola di blocco HTTP:

- **Ping (ICMP)** → esito positivo
- **Accesso DVWA (HTTP)** → esito negativo (timeout)



Ping – Esito positivo Accesso DVWA – Esito negativo

Figura 8 – Blocco accesso DVWA tramite firewall (HTTP)

Analisi tecnica

Il firewall applica un filtraggio selettivo del traffico tra le reti:

- consente il traffico ICMP, permettendo la verifica della connettività;
- blocca il traffico TCP sulla porta 80 (HTTP), impedendo l'accesso all'applicazione DVWA.

Questo dimostra la capacità di controllare il traffico mantenendo attiva la rete e limitando l'accesso ai servizi non autorizzati.

Il messaggio di errore (timeout) conferma il blocco del servizio HTTP.

Esempio in ambito aziendale

In una rete aziendale, una configurazione simile permette di:

- impedire l'accesso diretto degli utenti ai server;
- limitare i servizi ai soli necessari;
- controllare le comunicazioni tra client e sistemi critici.

Riducendo il rischio di accessi non autorizzati senza compromettere l'operatività.

Conclusione dell'analisi

Il filtraggio selettivo consente di applicare politiche di sicurezza efficaci, controllando le comunicazioni senza compromettere la rete.

9. Considerazioni di sicurezza

L'attività evidenzia l'importanza della separazione tra reti (LAN e OPT1), che consente di isolare client e server.

Le regole firewall permettono di controllare il traffico in modo mirato, ad esempio consentendo il ping e bloccando l'accesso al servizio web (porta 80).

È fondamentale anche l'ordine delle regole, che determina il comportamento del traffico.

Nel complesso, il firewall consente di gestire efficacemente la sicurezza senza interrompere la comunicazione.

10. Conclusione

L'attività ha dimostrato il corretto funzionamento di pfSense e la capacità di controllare il traffico tra sottoreti tramite regole di blocco totale e selettivo.

Il sistema rappresenta un modello valido per ambienti aziendali in cui è necessario segmentare la rete, proteggere i servizi critici e controllare le comunicazioni.